# WeConnect 2.0 — Retest Response

Independent verification of the Bug Status triage

| | |
|---|---|
| **Prepared for** | Lighthouse Communities Foundation |
| **Date** | 4 November 2026 |
| **Basis** | Bug Status sheet (84 findings), current `dev` source, live `api-dev`, and an isolated stack rebuilt from current source |

Each finding was retested against three layers: the current source, the live `api-dev` backend, and a stack rebuilt from current source for write behaviour. Fixes marked "Fixed on UAT" were also checked against the deployed UAT bundle. Verdicts below cite the layer the evidence rests on. The full per-finding detail is in the annotated Bug Status sheet.

## 1. Summary

| Outcome | Count | Findings |
|---|---|---|
| Reported fixed, confirmed fixed | 12 | incl. WC-011, WC-130, WC-095, WC-122, WC-018, WC-027 (nav) |
| Reported fixed, still present | 12 | WC-084, WC-043, WC-074, WC-077, WC-078, WC-080, WC-088, WC-089, WC-101, WC-123, WC-126, WC-128 |
| "Not a Bug", disputed | 10 | WC-004, WC-013, WC-023, WC-035, WC-073, WC-079, WC-109, WC-112, WC-115, WC-121 |
| Reclassifications accepted | 37 | config/deployment and documentation/handover items, and genuine non-bugs |
| New findings (not in the sheet) | 5 | WC-133, WC-134, WC-136, WC-140, WC-141 |

## 2. Reported "Fixed" — still present

Each was marked Fixed; each still reproduces.

- **WC-084 (S1).** The note claims a centre check "via `user_can_access_centre`." That function does not exist in `batch_management.py`; `close_batch` still saves with `ignore_permissions=True` and no check. Runtime: a Skilling Partner permitted only for East and West closed a North batch ("Batch closed successfully"). Severity S1 stands.
- **WC-128.** The note says the production build strips console output. The deployed `/auth/` bundle still contains `console.log("OTP Generation Response: ", ...)` and logs the reset email and OTP. The strip applies to OC, not to the auth app where the reset flow runs.
- **WC-126.** Runtime: every status transition is accepted — Skilling Invoice 30 of 30, Skilling Batch 72 of 72. No state machine.
- **WC-123.** Runtime: an account wrote a field on another user's record (HTTP 200). `update_profile` has no active permission check.
- **WC-078.** `delete_file_by_url` resolves a file by URL and deletes it with no owner or permission check.
- **WC-080.** `move_youth` creates a batch-transfer approval with no caller check.
- **WC-077.** The unauthenticated endpoint still carries `allow_guest` and assigns `System Manager`.
- **WC-088.** The `id = json.loads(id)` typo is still at both sites.
- **WC-089 / WC-101.** Runtime: endpoints return HTTP 500 on malformed input instead of 400; `add_remarks` raises a `TypeError`.
- **WC-074.** Runtime: `close_batch` returns HTTP 200 on a failed call.

- **WC-043.** The null-navigation crash persists; only two of nine apps define an error boundary to contain it.

## 3. "Not a Bug" — disputed

Conceded reclassifications are in section 4. The following are security-relevant and remain present.

- **WC-115.** Marked both "Valid Bug" and "Not a Bug". `sync_to_lcf_mastersheet` still has no authorisation check; any authenticated account, including an external Skilling Partner, can export programme data to an external spreadsheet. OWASP API6.
- **WC-079 / WC-073 / WC-035.** The permission model still does not exist as designed; 326 `ignore_permissions` sites bypass authorisation. This is the root cause behind the cross-centre write breaches (WC-084, and the residual in WC-095/WC-048).
- **WC-013.** The API secret is still written to `localStorage` at 18 sites. Any cross-site scripting on the domain exfiltrates a long-lived credential.
- **WC-004.** 28 `.env` files remain committed.
- **WC-109.** `dashboard.get_invoice_count` returns a global financial total with no scoping; any account sees organisation-wide figures.
- **WC-121 / WC-112 / WC-023.** "Config/Deployment" is a fair label, but all three are still live on `api-dev`: CORS reflects any origin with credentials, no security headers are sent, and tracebacks appear in error bodies. The label is accepted; closure is not.

## 4. Reclassifications accepted

The "Config/Deployment" framing is accepted for the concurrency, CORS, header, traceback and session items; they are deployment configuration, not code defects, and still need resolving. The "Documentation/Handover" framing is accepted for the permission-model-in-no-repository, runtime-config and fresh-install items. WC-009, WC-117, WC-002, WC-092 and WC-104 are accepted as non-bugs or by-design. WC-068 is a fair partial downgrade. Genuine fixes confirmed: the auth guard (WC-011), the stored-HTML sink (WC-130), the cross-centre invoice for ordinary accounts (WC-095, WC-085), mass assignment (WC-122, now 23 of 28 sites guarded), the navigation list structure (WC-027, by axe), and WC-018, WC-041, WC-010, WC-005, WC-006, WC-007, WC-014.

## 5. Severity

Only one downgrade is contested on risk grounds. **WC-048** (S1→S3): the stated reason, "bypass only for Administrator," is inaccurate — the gate is still `System Manager`. The disclosure is scoped for ordinary accounts (all six persona accounts confirmed non-`System Manager`), but the bypass remains reachable by any `System Manager` account on youth counselling data. Recommended severity S2. Two further downgrades are noted without a hard objection: WC-013 (credential exposure, rated S2 here) and WC-126 (uncontrolled financial-state transitions). The other 23 downgrades are accepted.

## 6. New findings (not in the Bug Status sheet)

- **WC-140 (S2).** `App.jsx` in six frontend apps (OC, CH, FC, SP, SYC, PYC) hardcodes an `api_key`/`api_secret` pair and a real staff `sid`, email and employee ID. A Frappe key/secret pair is a working credential. Rotate every exposed secret, remove them from source and git history, and load development credentials from untracked configuration.
- **WC-141 (S3).** A button without an accessible name and a scrollable region that cannot take keyboard focus, found by axe on the deployed OC app.

- **WC-133 (S2).** Seven of nine frontend apps define no error boundary; a component fault blanks the screen (the mechanism behind WC-016/WC-043).
- **WC-134 (S3).** 201 image elements have no `alt` attribute (264 at first report).
- **WC-136 (S3).** Seven routes crash for an account with no assigned centres, a real state for newly onboarded staff.